SK Shieldus Rookies

경영진 보고

모의 교육 플랫폼 취약점 진단 결과

러닝브릿지(가상) 온라인 교육 플랫폼

전체 위험 수준	진단 일자	문서 번호	작성
심각	2026-10-02	SCAN-2026-002-E	SK쉴더스 루키즈 34기 1석삼조 팀

본 보고서는 SK쉴더스 루키즈 교육과정의 프로젝트 산출물이며, SK쉴더스의 공식 진단 보고서가 아닙니다.

다른 수강생의 개인정보가 무단으로 조회될 수 있습니다

러닝브릿지의 온라인 교육 플랫폼에서 수강생 계정으로 로그인한 후, 성적 조회 URL의 student_id 값을 변경하면 다른 수강생의 이름, 연락처, 성적이 노출될 수 있습니다. 이로 인해 약 120,000명의 개인정보가 위험에 처할 수 있으며, 이는 개인정보 보호법 위반 소지가 있습니다.

전체 위험 수준

심각

개인정보를 처리하는 자산에 '상' 위험 취약점이 있음

취약 항목

1 건 / 점검 2개 항목

상 1건, 중 0건, 하 0건

영향받는 개인정보 처리 자산

1 개

교육 플랫폼 웹서버

1 수강생 개인정보가 무단으로 노출될 수 있음 상

수강생의 이름, 연락처, 성적 등의 개인정보가 권한 없는 자에게 노출되어 법적 책임과 신뢰 손실을 초래할 수 있습니다.

관련 법령 개인정보 보호법 제29조(안전조치의무) 검토 전

관련 법령 개인정보의 안전성 확보조치 기준 제5조 제1항(접근 권한의 관리) 검토 전

관련 법령 개인정보의 안전성 확보조치 기준 제6조 제3항(접근통제) 검토 전

유사 사례 경북대학교 · 파라미터 변조, 웹셸 업로드 관련 통제 **과징금 5,750만 원, 과태료 720만 원, 공표**

유사 사례 루이비통코리아(유) · 권한 확인 누락, 본인확인 미흡 관련 통제 **과징금 213억 8,500만 원, 공표명령**

관련 법령과 인증기준

조항·기준	관련 취약점	상태
개인정보 보호법 제29조(안전조치의무)	1건	검토 전
개인정보의 안전성 확보조치 기준 제5조 제1항(접근 권한의 관리)	1건	검토 전
개인정보의 안전성 확보조치 기준 제6조 제3항(접근통제)	1건	검토 전
ISMS-P 2.6.3 응용프로그램 접근	1건	검토 전

유사 처분·보도 사례

과징금 처분 개인정보위 2023-10-12 관련 통제

경북대학교 · 파라미터 변조, 웹셸 업로드

과징금 5,750만 원, 과태료 720만 원, 공표

과징금 처분 개인정보위 2026-02-12 관련 통제

루이비통코리아(유) · 권한 확인 누락, 본인확인 미흡

과징금 213억 8,500만 원, 공표명령

'검토 전'은 AI가 매핑하고 담당자가 아직 확인하지 않은 항목입니다. 확정 전까지는 위반 소지로 보아야 합니다.
사례 등급: 동일 결함 = 인증기준과 취약점 유형이 모두 같음, 같은 유형 = 취약점 유형이 같음, 관련 통제 = 인증기준만 같음.

과징금 노출과 감경 여지

최대 노출액 (법정 상한)

1억 5,000만 원

연 매출 50억 원의 3%. 제29조(안전조치의무)에 취약점 1건 해당

투자 감경 반영 시 (예시)

9,000만 원

보호 투자·조치 기록이 있으면 최대 40% 감경. 지금은 기록이 없어 감경 근거가 없음

10% 특례 시나리오

5억 원

반복 위반, 1천만 명 이상 피해, 시정명령 불이행으로 유출될 때만. 현재 요건 해당 없음

같은 유형 결함의 실제 과징금

유사 처분 4건 · 최소 5,750만 원 · 중앙값 358,655,000원 · 최대 213억 8,500만 원

사례	처분일	과징금
루이비통코리아(유) · 권한 확인 누락, 본인확인 미흡 관련 통제	2026-02-12	213억 8,500만 원
공무원연금공단 · 권한 확인 누락, 본인확인 미흡 관련 통제	2026-03-26	5억 3,200만 원
한화호텔앤드리조트㈜ · 권한 확인 누락 관련 통제	2024-08-28	1억 8,531만 원
경북대학교 · 파라미터 변조, 웹셸 업로드 관련 통제	2023-10-12	5,750만 원

법정 상한은 최대치이며 예상 부과액이 아닙니다. 실제 부과액은 과징금 부과기준의 산정 단계(기준금액, 감경, 조정)를 거쳐 정해집니다.
유사 사례 금액이 상한보다 큰 것은 사례 기업의 매출 규모가 더 크기 때문이며, 같은 결함이 실제로 처분받은 규모를 보여주기 위한 참고값입니다.

조치 로드맵

즉시 1주 이내

서버 사이드 사용자 권한 검증 로직 구현

신규 스캐너 점검 항목

단기 1개월 이내

해당 없음

중기 분기 이내

해당 없음

경영진 결정이 필요한 사항

1 **수강생 개인정보 보호를 위해 즉시 서버 권한 검증 로직 구현을 승인해 주십시오.**

2 **향후 과징금 감경을 위해 보안 조치 및 투자 기록 관리를 위한 예산을 승인해 주십시오.**

취약점별 상세 내용과 조치 방법은 실무진용 상세 보고서(SCAN-2026-002-T)에 있습니다. 법령·인증기준 매핑 중 4건은 아직 담당자 검토 전입니다.